

Operation Oni

 **Security Warning:** Work in an isolated environment (virtual machine or container). Never open unknown files on your primary machine.

Challenge Description

Download this disk image, find the key and log into the remote machine.

Note: If you are using the webshell, download and extract the disk image into `/tmp`, not your home directory.

Additional details will be available after launching your challenge instance.

After launching the instance, you receive:

Download disk image

Remote machine: `ssh -i key_file -p 58567 ctf-player@saturn.picoctf.net`

Note: The port number changes with each launch.

Tools Used

- `7z` – Extract compressed files
 - `file` – Determine file type
 - `mmls` – Display partition layout (Sleuth Kit)
 - `fls` – List files in a disk image (Sleuth Kit)
 - `icat` – Retrieve a file by inode number (Sleuth Kit)
 - `chmod` – Change file permissions (SSH requires 600)
 - `ssh` – Connect to remote machine
-

Complete Solution

Step 1: Download and Extract

Download the disk image named `disk.img.gz` from the challenge page.

Extract the compressed disk image:

```
7z x disk.img.gz
```

This decompresses the gzipped file and creates the raw disk image `disk.img`.

Step 2: Basic File Inspection

Verify the file type and understand its structure:

```
file disk.img
```

Expected output:

```
disk.img: DOS/MBR boot sector; partition 1 : ID=0x83, active, start-CHS (0x0,32,33),
end-CHS (0xc,223,19), startsector 2048, 204800 sectors; partition 2 : ID=0x83, start-
CHS (0xc,223,20), end-CHS (0x1d,81,52), startsector 206848, 264192 sectors
```

The output confirms this is a **DOS/MBR boot sector** with three partitions. We need to find where the SSH key is stored.

Step 3: View Partitions with mmls

Use `mmls` to see the partition layout more clearly:

```
mmls disk.img
```

Expected output:

```
DOS Partition Table
Offset Sector: 0
Units are in 512-byte sectors
```

Slot	Start	End	Length	Description
------	-------	-----	--------	-------------

000:	Meta	0000000000	0000000000	0000000001	Primary Table (#0)
001:	-----	0000000000	0000002047	0000002048	Unallocated
002:	000:000	0000002048	0000206847	0000204800	Linux (0x83)
003:	000:001	0000206848	0000471039	0000264192	Linux (0x83)

We have two Linux partitions starting at offsets:

- **Partition 2:** start sector `2048`
- **Partition 3:** start sector `206848`

Step 4: Explore the Partitions with fls

Let's examine the second partition (offset `206848`) first:

```
fls -r -o 206848 disk.img
```

This recursively lists all files. Look for anything interesting – especially `.ssh` directories or key files.

Now examine the `root` directory (inode `470` in this partition):

```
fls -o 206848 disk.img 470
```

Output:

```
r/r 2344:      .ash_history
d/d 3916:      .ssh
```

Key finding: A `.ssh` directory exists! This likely contains SSH keys.

Step 5: List Contents of the .ssh Directory

```
fls -o 206848 disk.img 3916
```

Output:

```
r/r 2345:      id_ed25519
r/r 2346:      id_ed25519.pub
```

The private key `id_ed25519` (inode `2345`) is exactly what we need to connect to the remote machine!

Step 6: Extract the SSH Private Key

Use `icat` to extract the private key:

```
icat -o 206848 disk.img 2345
```

Output:

```
-----BEGIN OPENSSH PRIVATE KEY-----  
<REDACTED>  
-----END OPENSSH PRIVATE KEY-----
```

Save it to a file:

```
icat -o 206848 disk.img 2345 > key_file
```

Step 7: Set Correct Permissions

SSH requires strict permissions on private key files:

```
chmod 600 key_file
```

Step 8: Connect to the Remote Machine

Use the key to connect via SSH:

```
ssh -i key_file -p 58567 ctf-player@saturn.picoctf.net
```

Output:

```
The authenticity of host '[saturn.picoctf.net]:62277 ([13.59.203.175]:62277)' can't be  
established.
```

```
ED25519 key fingerprint is: SHA256:XBSvB1lk28EctsAVdKJtsl0A7C5bonqPrvHCYH8aEy4
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[saturn.picocft.net]:62277' (ED25519) to the list of known
hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 20.04.5 LTS (GNU/Linux 6.8.0-1053-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
```

This system has been minimized by removing packages and content that are not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

```
ctf-player@challenge:~$
```

Step 9: Read the Flag

Once connected, list the files:

```
ctf-player@challenge:~$ ls
flag.txt
```

Read the flag:

```
ctf-player@challenge:~$ cat flag.txt
```

Output:

✔ Final Result

picoCTF{<REDACTED>}

Note: The actual flag is redacted here. In the real challenge, following these steps will reveal the complete flag.

🧠 Key Concepts

Concept	Description
MBR (Master Boot Record)	The first sector of a disk that contains the partition table.
Linux Partition (0x83)	Partition type identifier for a native Linux filesystem (ext4).
mmls	Sleuth Kit tool that displays partition layouts.
fls	Lists files and directories in a disk image by inode numbers.
icat	Retrieves a file by its inode number without mounting the filesystem.
SSH Private Key	Used for authentication; must have <code>600</code> permissions (<code>chmod 600</code>).
.ssh Directory	Stores SSH keys (<code>id_ed25519</code> , <code>id_rsa</code> , etc.) for secure authentication.

💡 Pro Tips

1. **Use `mm1s` to find partitions** – It's often clearer than `fdisk` for forensic analysis.
2. **`fls -r` recursively lists files** – Great for exploring the entire filesystem structure.
3. **Look for `.ssh` directories** – They often contain private keys that grant remote access.
4. **SSH keys are in `id_*` files** – `id_ed25519` , `id_rsa` , `id_ecdsa` , etc.
5. **`chmod 600` is essential** – SSH will refuse to use a private key with loose permissions.
6. **The port changes each time** – Always check the port number after launching the instance.
7. **`icat` works without mounting** – Perfect for extracting files when you can't or don't want to mount.

Alternative SSH Key Permissions

Permission	Description
<code>600</code> (owner read/write)	Required for private keys
<code>644</code> (owner read/write, group read)	May cause SSH to refuse
<code>666</code> (anyone read/write)	SSH will reject immediately